Atlas Continental ransomware incident - PCAP analysis

Capture: `atlas_continental_ransomware_incident.pcap` - 863 packets / 109 kB - 2026-09-01 08:13 -> 2026-09-08 16:14 (times as displayed, UTC+03:00) **Verdict:** phishing -> implant -> C2 -> data theft -> encryption -> paid ransom -> decryption. The whole intrusion is visible end to end in this traffic.

What happened

1. **Phishing (1 Sep 08:14).** An external relay delivered "2026 Salary Increase Notification" to `d.kowalski@atlascontinental.com` with the attachment `SalaryIncrease.pdf.exe`.
2. **Implant (1 Sep 09:03).** Host `10.10.5.47` downloaded `svchost_update.bin` from `cdn-updates-secure.xyz`, one minute before its first check-in.
3. **Command and control (1-2 Sep).** 50 HTTP `POST /beacon` calls from 44 hosts across all six offices, in waves roughly every three hours.
4. **Data theft (3 Sep 03:14-04:14).** Five archive transfers to `45.147.230.55:443`, 15 minutes apart: financial, customer, source code, employee PII and engineering data.
5. **Encryption (3 Sep 10:08-10:18).** SMB connections to the file server in each office: ransom note written, then every share renamed to `*.gentlemen_locked`.
6. **Negotiation (3-7 Sep).** Tor session to `91.219.237.44:9050`: demand 5,000,000 USD, settled at 1,250,000 USD.
7. **Payment (6-7 Sep).** Bitcoin transaction broadcast 6 Sep 22:09, six confirmations by 7 Sep 00:19; payment verified through a public chain API.
8. **Decryption (7 Sep 01:13-01:38).** Decryptor run against all six shares; the chat hands over a universal key.
9. **Aftermath.** Plain HTTP heartbeats to `95.216.201.77:443` continue every six hours until the capture ends on 8 Sep 16:14 - the attacker kept a foothold after "closing" the case.

Timeline

Time (UTC+03)	Stage	Evidence
09-01 08:14	Phishing email d..	SMTP from 194.61.32.15 to 10.10.1.30:25, attachment ..
09-01 09:03	Payload download	GET /update/svchost_update.bin from cdn-updates-secu..
09-01 09:04	First check-in	POST /beacon from 10.10.5.47
09-01 19:14 - 09-..	Beaconing spreads	50 beacons, 44 hosts, six offices, ~3 h apart

Time (UTC+03)	Stage	Evidence
09-03 03:14-04:14	Exfiltration	5 archives -> 45.147.230.55:443
09-03 10:08-10:18	Ransom note + en..	SMB \\10.x.1.20\Shared, rename to .gentlemen_locked
09-03 18:13 - 09-..	Negotiation over..	10.10.1.30 91.219.237.44:9050
09-06 22:09	Payment broadcast	TXID 3f9a7c2e...b5a2f
09-07 00:19	6 confirmations	chain API 104.21.55.9, 19.84 BTC
09-07 01:13-01:38	Decryption	DECRYPT_TOOL on all six shares
09-07 04:14 - 09-..	Heartbeats conti..	POST /hb to 95.216.201.77:443

Infrastructure

Role	Address / domain
Phishing relay	194.61.32.15 (mail-relay.atlas-hr-payroll-secure.net)
Payload host + beacon C2	cdn-updates-secure.xyz -> 45.147.230.12 (TCP 80)
Exfiltration	45.147.230.55:443
Negotiation portal (Tor)	91.219.237.44:9050
Payment verification	104.21.55.9 (chain-explorer-btc.example, Cloudflare)
Post-incident C2	95.216.201.77:443 (POST /hb)
Attacker mailbox	hr.payroll@atlas-hr-payroll-secure.net
Wallet	bc1qthegentlemen7x9k2m4n8p1q5r3s6t8u9v0w2x4y6z
Onion portal	thegentlemenxyz7q9k2m4n8p1q5r3s6t.onion

Compromised hosts: patient zero `10.10.5.47`, plus 43 other workstations across `10.10`, `10.20`, `10.30`, `10.40`, `10.50` and `10.60`; file servers `10.x.1.20`; mail gateway `10.10.1.30`.

Stolen data (as declared in the exfiltration manifests)

Archive	Category	File
1000	Financial records	Q1-Q4_2026_Consolidated_Financials.xlsx.t..
1001	Customer data	Global_Customer_Database_Export.sql.tar.g..
1002	Source code	Atlas_Core_Platform_Source_Repositories.t..
1003	Employee PII	Global_HR_Employee_Records_AllOffices.csv..
1004	Engineering archives	Product_Design_And_Engineering_Archives.t..

Roughly 600 TB claimed. The pcap carries manifest headers and placeholder chunks, so the transfer sizes above are the attacker's claims, not bytes on the wire (each transfer is ~6 kB in this capture).

Extortion sequence

- Demand 5,000,000 USD; victim offers 750,000; attacker counters 4,500,000,

victim 1,000,000, final agreement **1,250,000 USD**.

- Attacker supplied a free decryption of `HR_template_locked.gentlemen_locked`

as proof of capability before payment.

- Payment verified on-chain (6 confirmations) before the key was released:

`8F3D1A9C7E2B5D6F0A4C8E1B3D7F9A2C5E8B1D4F7A0C3E6B9D2F5A8C1E4B7D0F`, valid for all

six offices.

- Attacker instructed the victim not to involve law enforcement.

Defensive observations

- **Email:** the lure used a lookalike payroll domain and a double extension

(`SalaryIncrease.pdf.exe`). SPF/DKIM/DMARC and attachment filtering would have stopped it at the gateway.

- **C2:** beaconing is regular (~3 h), to a single IP over plain HTTP, from 44

hosts across every site. Beacon traffic to one destination from many internal hosts is the easiest signal to alert on here.

- **Lateral / encryption:** SMB ran on a non-standard port (`4455`), and the

mass rename to `*.gentlemen_locked` across six shares happened in ten minutes. Share-level write protection and an alert on bulk renames would have cost the attacker time.

- **Exfiltration:** five large outbound transfers on port 443 over one hour -

egress filtering and volume thresholds would have caught it.

- **Tor:** `10.10.1.30` opened a SOCKS session to `91.219.237.44:9050` and held

it for days; blocking 9050 egress and alerting on Tor use is low-effort.

- **Persistence:** heartbeats to `95.216.201.77` continued for two days after

the "resolved" chat - the case was closed while the intruder was still talking. Isolation should follow containment, not negotiation.

Immediate actions

1. Block the six external addresses, the domains, the wallet and the onion

portal at the perimeter, DNS and mail gateway.

2. Treat 44 workstations, six file servers and the mail gateway as

compromised: rebuild rather than clean. Reset credentials, rotate service accounts and keys.

3. Disable SMB on non-standard ports between segments; audit share

permissions for mass-write paths.

4. Hunt for `svchost_update.bin`, `SalaryIncrease.pdf.exe`,

`README_DECRYPT_THE_GENTLEMEN.txt`, `*.gentlemen_locked` and the decryptor tool on disk, and for `/beacon` and `/hb` in proxy logs.

5. Preserve the pcap, chat transcript and transaction hashes for law

enforcement and the insurer; assume the data remains public if the actor changes its mind.